

Description of Work (DOW) for:

Web Developer Security Engineering Services (SMA4)

1.1 Objectives

The Web Developer Security Engineering plays a pivotal role in protecting mission-critical web applications, APIs and sensitive data. The objectives are to embed robust security principles throughout the software development lifecycle (SDLC) to build security as a proactive, foundational pillar.

1.2 Scope of Work

The scope of work includes, but is not limited to, the following activities:

Web Application Security

- Identify, analyze, and neutralize critical vulnerabilities, logic flaws, insecure dependencies, and misconfigurations
- Drive the end-to-end vulnerability lifecycle - integrating proactive threat modeling and advanced security assessments, ensuring remediation integrity through rigorous technical validation
- Support integration of security controls into application architectures, APIs, and supporting services, advising on secure design patterns; data protection mechanisms; and secure communication protocols to ensure applications are secure by design and resilient to evolving threats

Monitoring, Logging, Incident Response and Automation

- Obtain, review, and analyze web server and application logs to detect anomalies and indicators of compromise
- Implement automation scripts for threat intelligence integration to optimize alert accuracy and actively support the end-to-end response to web application security events.
- Maintain documentation of findings, remediation steps, and security controls

Compliance & Governance

- Ensure all web applications and cloud infrastructures comply with Federal cybersecurity frameworks, including NIST SP 800-53, FISMA, and FedRAMP (as applicable)
- Participate in audits, risk assessments, and security authorization processes

1.3 Key Personnel

The following role is anticipated to be required for this work and is considered Key Personnel, in accordance with SOW paragraph 2.9.

- Web Developer Security Engineer

1.3.1 Key Personnel Requirements

The Contractor shall provide a Web Developer Security Engineer who meets the following specific requirements:

- Extensive hands-on experience in secure software development, DevSecOps automation, and vulnerability remediation.
- Proficiency in logs analysis, file integrity monitoring (FIM), and managing web application firewalls (WAF) to defend against emerging threats.
- Minimum of 3 years of experience in Web Application Security, Application Security Engineering (AppSec) or secure software development life cycle (SSDLC)
- Proven developing with modern web technologies and frameworks not limited to .NET (C# MVC, WCF), HTML5, CSS3, JavaScript, REST APIs, and SQL
- Ability to leverage AI-assisted development tools (e.g., GitHub Copilot, OpenAI API/Codex) and scripting languages (Python, JavaScript/Node.js, Java, React.js, TypeScript) to automate security monitoring and compliance audits
- Strong understanding of Open Worldwide Application Security Project (OWASP) Top 10, secure coding standards, and proactive mitigation of common web vulnerabilities.
- Experience deploying, tuning, and maintaining Web Application Firewalls (WAFs) solutions tailored to custom-developed applications and traffic patterns.
- Strong track record in configuring and managing File Integrity Monitoring (FIM) solutions for web content directories, to detect and alert on unauthorized change.
- Familiar with security testing tools such as Wireshark, SIEM, IDS/IPS, NDR, or EDR
- Evaluates, recommends, and implements security controls for mobile device solutions and mobile-web interface.
- Ability to perform complex risk assessments, analyze cyber threats, and provide remediation guidance for core systems and their dependencies
- Proven ability to implement DevSecOps principles, seamlessly integrating security controls throughout the CI/CD pipeline
- Experience developing security metrics, managing compliance reporting, and auditing systems against established security baselines
- Collaborate effectively across multidisciplinary teams, and work independently as well as in a team
- Experience providing Tier II support for security operations and recommending continue security enhancements for existing infrastructure.

Preferred

- In-depth experience at Federal cybersecurity frameworks (NIST SP 800-53, FISMA, FedRAMP) authorization process
- Proven background in threat modeling, risk assessment, and designing resilient security architecture

- Advanced experience implementing secure DevOps/DevSecOps practices, specifically focus on CI/CD pipeline and automating security gates
- Knowledge of cloud security AWS and container security (Docker, Kubernetes)

1.3.2 Required Education & Credentials

- Bachelor's degree (or higher) in computer science, Cybersecurity, Information Systems, Engineering, or a related field.

The candidate(s) provided by the Contractor must have the following current credentials:

- Specialized AppSec:
 - Certified Secure Software Lifecycle Professional (CSSLP)
 - GIAC Certified Web Application Defender (GWEB)
 - EC-Council Certified Application Security Engineer (CASE)
- Offensive Security:
 - OffSec Web Expert (OSWE)
 - Offensive Security Certified Professional (OSCP)
- Foundational Security:
 - Security+
 - GSEC

These (or their equivalent prior certifications) should have been maintained for a minimum of 5 years. Expired certifications or certifications never used professionally will not be considered.

1.6 Government Furnished Equipment and Information

Pursuant to SOW paragraph 2.5, Government-Furnished Property, the Government will provide the following to perform the tasks outlined in this Description of Work:

- CBO-issued laptops, mobile devices, and peripheral hardware (if required)
- Access to internal systems for testing access to tools such as Momentum, Microsoft 365, SharePoint, Zoom, Cisco Webex, and VPN credentials
- Network diagrams, system architecture documentation, current firewall rule sets, and relevant configuration files
- Applicable policies, procedures, and security baselines (e.g., NIST, FISMA, IRS 1075 guidelines)
- Contact information for internal technical points of contact (POCs) and data center operations